

Secure Software

Testat - Web Security

1 Introduction

You are a security engineer at XYZ company. As you visit the coffee corner in the office to get your morning dose of coffee, you encounter your new coworker Eve, who just started in another department the other day. She leans against the counter while talking to her colleagues in a proud voice. While you're making your coffee, you overhear their conversation. She claims she has found a way to make visitors of a certain website download her malware automatically. No clicks, no warnings, just a silent infection. A few coworkers laugh nervously, unsure whether she is joking, but as a security engineer, you become curious whether she is telling the truth. So you join the conversation, feigning curiosity instead of concern, and ask her about the webpage and how she managed to do it. Eve, overjoyed by your serious interest, happily chatters away.

She mentioned a search form, something about how it responded differently under certain inputs, allowing her to obtain the credentials of an admin account. Further she bragged about gaining access to the backend server by exploiting an upload form meant for configuring sales content. She realized it accepted more than it should, and that was her way in. From there, she planted her malicious file and connected it to the public facing site.

To avoid raising suspicion from Eve, you congratulate her on her cleverness, take your coffee, and head back to work. Your new work: To find the vulnerabilities Eve mentioned and write a report for the owner of the webpage.

2 Tasks

As described in the introduction, complete the tasks and write a report on the security vulnerabilities exploited by Eve, addressed to the website operator.

Please hand-in: A brief report covering the points described below. Please keep it as short as possible, but as long as you deem necessary.

- Explain your thoughts and approaches. Make sure to answer the following questions: What did you do? How did you do it? Why did you do it?
- **You do NOT need to find and change the actual code, but rather think about what might have caused the problem during implementation and how you would fix it.**
- Answer the questions asked.

i Subjective Difficulty of the Levels

Since, unlike in previous Testats, we're looking at three different vulnerabilities here, the difficulty levels were primarily assigned based on the progression of Eve's actions. Classifying the levels by difficulty is trickier, since you and your team members may have different levels of prior knowledge regarding the components of a 3-tier app, so the difficulty is subjective. Keep that in mind if you get stuck on a level. In some levels, you'll be given information at the start that you only need if you haven't (yet) solved the previous levels.

The vulnerable web app is a modified version of the Choco Shop, which you should already be familiar with from the exercises. You will run the app locally, as we do not want to host it publicly, since it is a vulnerable website and, in the event of an attack on the backend (which is part of the Testat), we can no longer guarantee that it is safe to use and available at all times.

i The Web Application Will NOT Harm Your Machine

Note that the web application is vulnerable and has been compromised by 'Evil Eve' (the INS security team at OST). When you visit the website, a file named **bad.txt** is downloaded at various points. We assure you that the file contains no malicious content and is in no way intended to harm your computer.

To run the app, make sure that `docker` is installed on your machine, if not, follow [these installation instructions](#). Also ensure that you can run `docker-compose`, if the plugin is missing, simply install it with `sudo apt install docker-compose-plugin`. Start the web application by running the following commands, which you can also find in the `start_webapp.txt` file:

```
$ docker login -u 'gitlab+deploy-token-725' -p 'gldt-q9a_f-zFRAaazmUxkpFT'  
registry.gitlab.ost.ch:45023/ins-courses/exams/secsow/web-security-application  
$ docker compose up -d  
  
# run the following command to logout again  
# docker logout registry.gitlab.ost.ch:45023
```

You can now access the website at <http://localhost:8080/>.

⚠ Treat your Local Webpage like a Public One

Yes, you can access the 'server backend' via Docker. Yes, the code is also available, and you could check it for vulnerabilities. Please don't do that! Treat your local 'hosting' environment as a black box. The goal of this test is to find vulnerabilities by identifying unexpected behavior during user interaction.

2.1 Level 1

You have created a standard user account with the following login credentials:

- Username: alice
- Password: alice.123

Log in and examine the site. Eve's malware must be downloaded automatically from somewhere.

Answer the following questions:

- What action triggers the download?
- Why is this even possible? What security vulnerability is at the root of this?
- What solution would you suggest to the operator?

2.2 Level 2

Let's find out how Eve gained access.

[Eve] mentioned a search form, something about how it responded differently under certain inputs, allowing her to obtain the credentials of an admin account.

Take a look at the search form. Your goal in this task is to obtain the admin login credentials. You'll need them in Level 3, but if you can't find them, use the ones provided in Level 3. (In this level, you should find the login credentials for a different admin than the one described in L3.)

Answer the following questions:

- What is the problem with the search form? What is the underlying security vulnerability?
- Show how Eve found the login credentials.
- What solution would you suggest to the operator?

Hint: You need a reverse proxy for this level.

2.3 Level 3

Further [Eve] bragged about gaining access to the backend server by exploiting an upload form meant for configuring sales content. She realized it accepted more than it should, and that was her way in. Now that you have administrator privileges, locate the upload form mentioned above and exploit a vulnerability in its design.

If you were unable to find the administrator credentials in L2, you can use the following credentials:

- Username: freeAdmin
- Password: SuperSecrete01

Answer the following questions:

- What is the problem with the upload form? What is the underlying security vulnerability?
- Explain how Eve could have uploaded the malware **bad.txt**.
- What solution would you suggest to the operator?